SECURELINK VPN LAB

Research Project | Secure VPN for Remote Access

Policy & Compliance Documentation

Establishing a Secure VPN for Remote Access

Deliverable D6 of 6

Organisation	Research project (lab build)
Author	Kshitij Rajesh Randhire
Version	1.0 (final)
Basis	Lab build on VMware; evidence IDs [E01]-[E38] refer to the evidence screenshot set
Status	Lab documentation. Not certified and not presented as production-ready.

Contents

1 Document control
2 Acceptable use policy
3 Security guidelines
4 Access control policy
5 Incident response
6 Roles and responsibilities
7 GDPR alignment
8 HIPAA Security Rule alignment
9 Gaps

1 Document control

Field	Value
Title	VPN Usage and Compliance Policy (lab draft)
Owner	Security officer (proposed role)
Author	Kshitij Rajesh Randhire
Version	1.0
Review cycle	Recommended: annually and after any incident
Status	Draft for review; not approved by any authority

This document aligns lab controls with GDPR and the HIPAA Security Rule. It is an alignment mapping, not legal advice and not a statement of compliance.

2 Acceptable use policy

- Use the VPN only for authorized company work.
- Do not share certificates, passwords or TOTP codes or devices with the VPN profile.
- Connect only from devices that pass the compliance check.
- Report a lost device or a suspected compromise immediately.
- Do not attempt to reach networks outside your authorization; blocked attempts are logged [E11].

3 Security guidelines

- AES-256 encryption and certificate plus TOTP authentication for every connection (D2).
- Keep OpenVPN at version 2.6.0 or later, keep private keys at mode 600 or stricter, keep the clock synchronized and a firewall active [E13][E14].
- Split tunnel is used; only corporate traffic goes through the VPN [E06].
- Logs are forwarded centrally (D4) and treated as sensitive.

4 Access control policy

Access is granted by network destination: VPN clients may reach 10.10.1.0/24 only; other destinations are logged and dropped [E11][E12]. Access requires a valid, unrevoked certificate and a TOTP code. Limits: the policy is network-based, not per user; the lab used one certificate and one account, so unique user identification is not demonstrated; rule persistence after reboot was not verified.

5 Incident response

Example: a lost or compromised client certificate, using the revocation test.

Phase	Action	Evidence
Detect	Alerts or log review: wrong-code failures,	[E09][E11][E19]

	VPN-DENY lines, unusual connections	
Contain	Revoke the certificate and regenerate the CRL (test at 23:39:38 UTC)	[E23]
Verify	Confirm new attempts are rejected (from 23:40:48 UTC, "certificate revoked")	[E24][E25]
Eradicate and recover	Reissue a new certificate and reset the user's TOTP enrolment	D2
Review	Record timeline, root cause and improvements; update this policy	-

Not tested: ending a session that was already established when the certificate was revoked. Add a manual step to disconnect the live session.

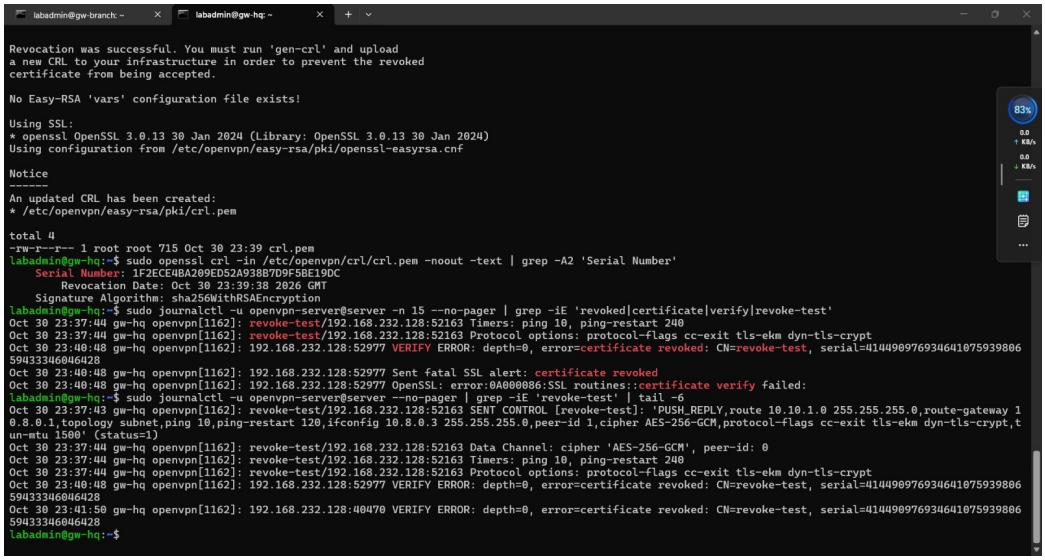


Figure 1. Revoked certificate accepted before revocation, rejected after [E24]

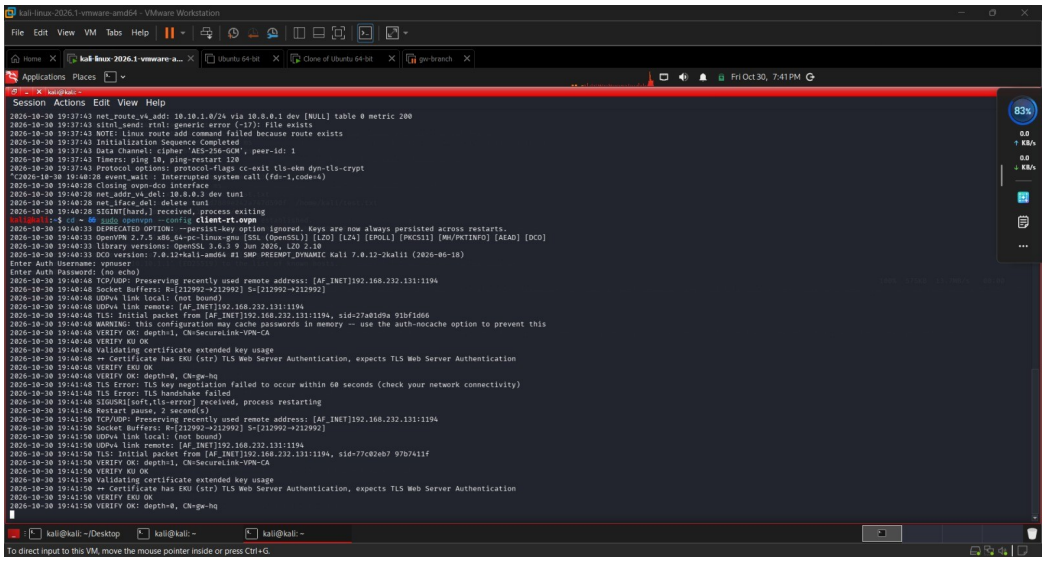


Figure 2. Client side: TLS key negotiation fails with the revoked certificate [E25]

6 Roles and responsibilities

Role	Responsibility
VPN administrator	Issues and revokes certificates, maintains gateways and logs
Security officer	Owns this policy, reviews logs, leads incident response
Data protection officer	Advises on GDPR matters, retention and breach notification
Users	Follow the acceptable use policy and report incidents
Management	Approves the policy and resources

Role names are proposals; the organisation would assign named people.

7 GDPR alignment

VPN and log data can include personal data such as user names and IP addresses.

Article	Requirement (summary)	Control / evidence	Status
Art. 5	Lawfulness, minimisation, integrity and confidentiality, storage limitation	Encryption and access limits [E05][E11]; logs may contain personal data; no retention settings	Partial; retention gap
Art. 25	Data protection by design and default	Split tunnel and destination-limited access [E06][E11]	Partial
Art. 30	Records of processing	VPN and log processing not yet recorded	Gap
Art. 32	Security of processing	AES-256, certificates, TOTP, logging [E05][E09][E27]	Partial; plain TCP 514 and single-tier PKI
Art. 33	Notify the authority within 72 hours of becoming aware of a breach	Incident procedure in section 5; no notification procedure written	Partial

8 HIPAA Security Rule alignment (45 CFR 164.312)

Standard	Control / evidence	Status
(a)(1) Access control	Certificate plus TOTP; destination-limited iptables [E07][E11]; one account used, so unique user identification not shown	Partial
(b) Audit controls	Logs from OpenVPN, auth, kernel; central forwarding [E09][E11][E28]; no alerting or retention	Partial
(c)(1) Integrity	AES-256-GCM, SHA-256 file match [E17] [E18]	Implemented in lab
(d) Person or entity authentication	Certificates and TOTP [E05][E09]	Implemented in lab; per-user identity not demonstrated

(e)(1) Transmission security	IPsec and OpenVPN encryption [E01][E05]; syslog link not encrypted	Partial

9 Gaps

Open gaps: per-user certificates and accounts; two-tier PKI; retention policy; records of processing; TLS syslog; alerting; tested macOS client; established-session cut-off; a named policy owner.